

BÁO CÁO KIỂM THỬ ESHOP (MAIN REPORT)

Thông tin sinh viên:

- Họ và tên: Đặng Đăng Khoa
 - Mã số sinh viên: 23127207
-

FR-02 – Authentication & Lockout

1. Feature Overview

- Pool: Pool A (Authentication & Authorization)
- Actor: Customer / Web Admin / System
- Related UI: `/login` (Web), `/login` (Admin)
- Related API: `POST /api/login`, `POST /api/admin/login`
- Preconditions: User account has been registered in the database.
- Business Rules: Lockout after 3 consecutive failures, lockout duration is 30s in demo environment, JWT token returned upon success.

2. Domain Testing Summary

- Link/detail: [tests/test-cases/login/](#)
- Number of Domain Test Cases: 41
- Main valid partitions: Đúng email + mật khẩu, Định dạng email hợp lệ, Casing mật khẩu chính xác
- Main invalid partitions: Sai email/mật khẩu, Thiếu email/mật khẩu, Sai định dạng email, Mật khẩu quá ngắn/quá dài
- Human review notes: AI ban đầu bỏ sót việc phân vùng kiểm thử độ nhạy chữ hoa/thường (casing) của email và tab navigation accessibility.

3. Boundary Value Analysis Summary

- Link/detail: [tests/test-cases/login/](#)
- Boundary variables: Độ dài email, độ dài mật khẩu, số lần thử sai, thời gian khóa
- Number of BVA Test Cases: 19
- Important boundary values: Password length (7, 8, 9, 39, 40, 41), Attempts count (2, 3, 4), Duration (29s, 30s, 31s)
- Human review notes: BVA phát hiện SUT đặt thời gian khóa cứng là 180s thay vì 30s trong database backend.

4. Test Execution Summary

Total TC	Executed	Passed	Failed	Blocked	Not Executed
80	30	11	19	0	50

5. Bugs Found

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR02-A-01	Bộ đếm đăng nhập sai tăng thêm 2 đơn vị thay vì 1	TC-LOGIN-002, TC-LOGIN-023	Major	High	Issue #31	Evidence
BUG-FR02-A-02	Thời gian khóa tài khoản bị thiết lập sai thành 3 phút	TC-LOGIN-003, TC-LOGIN-014, TC-LOGIN-025	Medium	High	Issue #32	Evidence
BUG-FR02-A-03	Race condition do xử lý yêu cầu đăng nhập bất đồng bộ	TC-LOGIN-002, TC-LOGIN-013, TC-LOGIN-023, TC-LOGIN-024	Major	High	Issue #33	Evidence
BUG-FR02-A-04	Tiêu đề trang Đăng nhập hiển thị sai thành “Đăng Ký”	TC-LOGIN-004	Minor	Medium	Issue #34	Evidence
BUG-FR02-A-05	Trường nhập Email hiển thị nhãn là “Username”	TC-LOGIN-004	Minor	Medium	Issue #35	Evidence
BUG-FR02-A-06	Nút submit biểu mẫu sử dụng tiếng Anh “Sign In”	TC-LOGIN-004	Minor	Medium	Issue #36	Evidence
BUG-FR02-A-07	Mật khẩu hiển thị ở dạng plain text (type=“text”)	TC-LOGIN-004	Critical	High	Issue #37	Evidence
BUG-FR02-A-08	Thiếu dấu hoa thị màu đỏ * đánh dấu trường bắt buộc	TC-LOGIN-004	Cosmetic	Low	Issue #38	Evidence
BUG-FR02-A-09	Thiếu trim khoảng trắng của Email ở phía Backend	TC-LOGIN-005	Medium	Medium	Issue #39	Evidence
BUG-FR02-A-10	Không tích hợp cơ chế Rate Limiting chống tấn công Brute-force	TC-LOGIN-008	High	High	Issue #40	Evidence
BUG-FR02-A-11	Nút submit không hiển thị Loading và không bị khóa khi đang xử lý	TC-LOGIN-009	Minor	Medium	Issue #41	Evidence
BUG-FR02-A-12	Không có nút Toggle ẩn/hiện mật khẩu trên biểu mẫu	TC-LOGIN-010	Cosmetic	Low	Issue #42	Evidence

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR02-A-13	Token JWT không có thời hạn hết hạn (vô hạn hạn)	TC-LOGIN-011	High	High	Issue #43	Evidence
BUG-FR02-A-14	Thiếu Route Guard ngăn truy cập lại trang Login khi đã đăng nhập	TC-LOGIN-012	Medium	Medium	Issue #44	Evidence
BUG-FR02-A-15	Giao diện đăng nhập Admin thiếu nhãn thông tin, thiếu dấu * bắt buộc và nút hiện mật khẩu	TC-LOGIN-013	Major	High	Issue #45	Evidence
BUG-FR02-A-16	Thông báo lỗi đăng nhập Admin sử dụng alert() gây hiển thị chữ "Code" và vi phạm vị trí thông báo	TC-LOGIN-004, TC-LOGIN-020, TC-LOGIN-021	Major	Medium	Issue #46	Evidence
BUG-FR02-A-17	Đặt lại mật khẩu thành công không giải phóng trạng thái khóa tài khoản và không reset bộ đếm lần đăng nhập sai	TC-LOGIN-004	Major	High	Issue #47	Evidence
BUG-FR02-A-18	Giao diện đăng nhập Frontend che khuất lỗi khóa tài khoản (luôn hiện thông báo lỗi tĩnh)	TC-LOGIN-...	Major	High	Issue #48	Evidence
BUG-FR02-A-19	API và giao diện thiếu cảnh báo số lần đăng nhập sai còn lại trước khi khóa	TC-LOGIN-030	Major	Medium	Issue #49	Evidence

6. AI Gap Analysis Summary

- What AI missed: Sai sót trong cấu hình lockout thời gian 180s ở DB, lỗi tab index bàn phím, race condition do query DB bất đồng bộ.
- What human corrected: Sinh viên phát hiện thêm lỗi race condition khi test thủ công nhiều tab và check tab focus UI.
- Why the gap happened: AI không có trải nghiệm giao diện trực quan và khả năng bắt đúng thời gian trễ ghi CSDL thực tế.
- Lesson learned: Cần kết hợp phân tích code backend để phát hiện bất đồng bộ race condition.

7. Evidence

- Screenshot folder: [tests/bug/login/evidences/](#)
 - Video/demo link nếu có: N/A
 - GitHub Issue links: #31 đến #49
-

FR-07 – Shopping Cart

1. Feature Overview

- Pool: Pool B (Shopping Cart)
- Actor: Customer
- Related UI: `/cart` , Product Details, Homepage Grid
- Related API: `GET /api/cart` , `POST /api/cart` , `DELETE /api/cart`
- Preconditions: User must be logged in.
- Business Rules: Add product increases quantity, confirmation dialog on delete, show total label as 'Tổng cộng', empty cart illustration.

2. Domain Testing Summary

- Link/detail: [tests/test-cases/cart/](#)
- Number of Domain Test Cases: 75
- Main valid partitions: Thêm sản phẩm, Xem giỏ hàng, Xóa sản phẩm xác nhận, Tính tổng tiền, Đồng bộ badge Navbar
- Main invalid partitions: Thêm không đăng nhập, Thêm thiếu id/price, price ≤ 0 , Xóa không xác nhận
- Human review notes: SUT thiếu hoàn toàn nút tăng giảm số lượng (+/-) trực tiếp trên trang `/cart` nên không thể thay đổi số lượng sau khi thêm.

3. Boundary Value Analysis Summary

- Link/detail: [tests/test-cases/cart/](#)
- Boundary variables: Số lượng quantity, giá sản phẩm price, dung lượng request body
- Number of BVA Test Cases: 15
- Important boundary values: Quantity (-1, 0, 1, 999999999), Price (0, 1, 1000, max_int)
- Human review notes: SUT cho phép thêm sản phẩm với quantity âm, bằng 0, thập phân và giá tiền giả mạo từ client.

4. Test Execution Summary

Total TC	Executed	Passed	Failed	Blocked	Not Executed
90	90	35	55	0	0

5. Bugs Found

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR07-B-01	Backend API không validate số lượng sản phẩm thêm vào giỏ hàng	TC-CART-044, TC-CART-045, TC-CART-046, TC-CART-047	Major	High	Issue #128	Evidence
BUG-FR07-B-02	Backend API không cộng dồn số lượng cho sản phẩm trùng ID	TC-CART-043	Major	High	Issue #129	Evidence
BUG-FR07-B-03	Frontend CartContext không cộng dồn số lượng khi thêm sản phẩm trùng	TC-CART-012	Major	High	Issue #130	Evidence
BUG-FR07-B-04	Trang giỏ hàng thiếu nút tăng giảm số lượng (+/-) và nhập số lượng trực tiếp	TC-CART-015, TC-CART-016, TC-CART-017, TC-CART-018, TC-CART-019, TC-CART-020, TC-CART-021, TC-CART-022, TC-CART-023, TC-CART-024, TC-CART-025	Major	High	Issue #131	Evidence
BUG-FR07-B-05	Thiếu Confirm Dialog xác nhận khi xóa sản phẩm khỏi giỏ hàng	TC-CART-031, TC-CART-032, TC-CART-033, TC-CART-075	Minor	Medium	Issue #132	Evidence
BUG-FR07-B-06	Nhãn hiển thị tổng tiền không đúng đặc tả ('Tổng tạm tính' thay vì 'Tổng cộng')	TC-CART-009	Minor	Low	Issue #133	Evidence
BUG-FR07-B-07	Trạng thái giỏ hàng trống thiếu hình ảnh/icon minh họa trực quan	TC-CART-002	Minor	Low	Issue #134	Evidence
BUG-FR07-B-08	Trang giỏ hàng thiếu thanh breadcrumb điều hướng	TC-CART-004	Minor	Low	Issue #135	Evidence

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR07-B-09	Không cần đăng nhập vẫn cho phép thêm sản phẩm vào giỏ hàng	TC-CART-...	Major	High	Issue #136	Evidence
BUG-FR07-B-10	Backend API không validate tính toán vẹn của sản phẩm thêm vào giỏ hàng	TC-CART-051, TC-CART-053, TC-CART-057, TC-CART-058, TC-CART-059	Major	High	Issue #137	Evidence
BUG-FR07-B-11	Thiếu thông báo phản hồi (toast/alert) khi thêm sản phẩm vào giỏ hàng thành công	TC-CART-010, TC-CART-011, TC-CART-038, TC-CART-074	Minor	Medium	Issue #138	Evidence
BUG-FR07-B-12	Không hiển thị số lượng hàng tồn kho khả dụng và thiếu cảnh báo khi số lượng vượt quá hàng tồn	TC-CART-060, TC-CART-079	Major	High	Issue #139	Evidence
BUG-FR07-B-13	Backend API cho phép giả mạo đơn giá của sản phẩm (Price Tampering)	TC-CART-063, TC-CART-064, TC-CART-080	Critical	High	Issue #140	Evidence
BUG-FR07-B-14	Backend API chấp nhận productId không tồn tại và tạo ra sản phẩm ma	TC-CART-061, TC-CART-062, TC-CART-078	Major	High	Issue #141	Evidence
BUG-FR07-B-15	Backend API không kiểm tra kiểu dữ liệu của trường quantity (Type Validation)	TC-CART-065, TC-CART-066, TC-CART-067, TC-CART-068	Major	High	Issue #142	Evidence
BUG-FR07-B-16	Lỗi hổng cho phép gán thuộc tính đặc quyền (Mass Assignment / Extra Fields)	TC-CART-070	Major	High	Issue #143	Evidence
BUG-FR07-B-17	Giao diện cho phép thanh toán (Checkout) khi giỏ hàng trống	TC-CART-076, TC-CART-077	Major	Medium	Issue #144	Evidence

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR07-B-18	Thiếu xử lý lỗi kết nối mạng hoặc sập máy chủ trên giao diện	TC-CART-...	Major	Medium	Issue #145	Evidence
BUG-FR07-B-19	Giỏ hàng không được làm sạch sau khi thanh toán thành công (checkout success)	TC-CART-089	Major	High	N/A	[Giao diện Web Checkout]

6. AI Gap Analysis Summary

- What AI missed: Lỗi không validate tính toàn vẹn của body JSON (thiếu id, price), cho phép giả mạo giá tiền của admin để mua rẻ.
- What human corrected: Sinh viên phân tích API payload và thực hiện giả mạo HTTP Request để phát hiện backend thiếu kiểm tra tính hợp lệ của giá bán gốc.
- Why the gap happened: AI sinh testcase tĩnh dựa trên mô tả cơ bản của giao diện mà bỏ qua các kịch bản kiểm tra bảo mật dữ liệu ở API backend.
- Lesson learned: Phải kiểm tra tính toàn vẹn và đồng bộ dữ liệu giữa Frontend và Backend DB.

7. Evidence

- Screenshot folder: [tests/bug/cart/evidences/](#)
- Video/demo link nếu có: N/A
- GitHub Issue links: N/A (local execution)

FR-13 – Dashboard

1. Feature Overview

- Pool: Pool C (Web Admin)
- Actor: Admin User
- Related UI: / (Web Admin home tab) or /admin/dashboard
- Related API: GET /api/admin/orders , GET /api/admin/users , GET /api/products , GET /api/categories , GET /api/coupons
- Preconditions:
 - Tài khoản Admin đã tồn tại và đăng nhập thành công.
 - JWT token được lưu trữ tại client.
 - Database đã có dữ liệu mẫu.
- Business Rules:
 - Chỉ admin được truy cập dashboard.
 - Doanh thu chỉ tính tổng total_amount từ các đơn hàng có trạng thái delivered .
 - Các số liệu thống kê không được âm.
 - Định dạng tiền tệ phải chuẩn VND (ví dụ: 150,000 đ).
 - Xử lý mượn mà khi database rỗng hoặc API gặp sự cố.

2. Domain Testing Summary

- Link/detail: [tests/test-cases/dashboard/](#)
- Number of Domain Test Cases: 24
- Main valid partitions:
 - Admin truy cập thành công với token hợp lệ và hiển thị thông tin chính xác.
 - UI xử lý chính xác khi không có dữ liệu (Empty Database) hoặc có dữ liệu các đơn hàng không phải delivered.
 - Co giãn giao diện tốt trên nhiều viewport (Desktop/Tablet/Mobile).
 - Regression retest thành công đối với lỗi nhân đôi doanh thu và lỗi backend admin APIs phân quyền.
- Main invalid partitions:
 - Khách hàng thường (customer) hoặc khách vắng lai (guest) bị chặn truy cập.
 - Token sai chữ ký hoặc hết hạn, hoặc token bị chỉnh sửa role từ client.
 - API orders/users bị lỗi 500 hoặc trả về sai định dạng dữ liệu (object thay vì array, thiếu thuộc tính total_amount).
 - Đơn hàng trả về có số tiền âm hoặc mang giá trị `null` / `NaN`.
- Human review notes: AI và sinh viên phát hiện lỗi bảo mật cực kỳ nghiêm trọng ở API backend (thiếu kiểm tra role của user khi gọi API admin) và lỗi tính sai doanh thu ở frontend (đơn hàng delivered bị nhân đôi giá trị).

3. Boundary Value Analysis Summary

- Link/detail: [tests/test-cases/dashboard/](#)
- Boundary variables: Tổng số đơn hàng, Tổng doanh thu, API Response Time, Số đơn hàng gần đây hiển thị, Breakpoint kích thước màn hình tablet, Số users/products âm hoặc thập phân.
- Number of BVA Test Cases: 22
- Important boundary values:
 - Tổng số đơn hàng: `-1` (invalid), `0` (min), `1` (min+1), `100,000` (max).
 - Tổng doanh thu: `-1 đ` (invalid), `0 đ` (min), `1 đ` (min+1), `999,999,999,999 đ` (max), cực đại `> Number.MAX_SAFE_INTEGER`.
 - API Response Time: `4900ms` (cận timeout), `5000ms` (đúng biên timeout), `5100ms` (quá timeout).
 - Số lượng đơn hàng gần đây hiển thị: `0` (min), `1` (min+1), `displayLimit` (max), `displayLimit+1` (vượt max).
 - Kích thước màn hình: `767px` (dưới breakpoint), `768px` (breakpoint tablet), `769px` (trên breakpoint).
 - Các số liệu thống kê khác: `-1` users, `10.5` products.
- Human review notes: Kiểm thử biên doanh thu 1 đ phát hiện ra giá trị hiển thị bị nhân đôi thành 2 đ trên giao diện thực tế.

4. Test Execution Summary

Total TC	Executed	Passed	Failed	Blocked	Not Executed
46	46	36	10	0	0

5. Bugs Found

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR13-C-01	Giao diện Dashboard hiển thị Tổng doanh thu bị nhân đôi	TC-DASHBOARD-DT-001, TC-DASHBOARD-BVA-006, TC-DASHBOARD-DT-023	Major	High	Issue #156	[Giao diện Dashboard Admin]
BUG-FR13-C-02	Backend API <code>/api/admin/orders</code> và <code>/api/admin/users</code> thiếu kiểm soát phân quyền (role)	TC-DASHBOARD-DT-004, TC-DASHBOARD-DT-013, TC-DASHBOARD-DT-014, TC-DASHBOARD-DT-024	Critical	High	Issue #157	[API Kiểm thử bảo mật]
BUG-FR13-C-03	Lỗi API <code>/api/admin/users</code> 500 ngắt toàn bộ tiến trình <code>fetchData</code> của dashboard	TC-DASHBOARD-DT-017	Medium	Medium	Issue #158	[Giao diện Dashboard Admin]
BUG-FR13-C-04	Order thiếu <code>total_amount</code> dẫn đến tính toán ra <code>NaN</code> đ hiển thị trên giao diện	TC-DASHBOARD-DT-020	Medium	Medium	Issue #159	[Giao diện Dashboard Admin]
BUG-FR13-C-05	Giao diện hiển thị trực tiếp số liệu thống kê âm hoặc thập phân mà không kiểm tra tính hợp lệ dữ liệu	TC-DASHBOARD-BVA-018, TC-DASHBOARD-BVA-019	Minor	Low	Issue #160	[Kiểm thử biên API]

[!NOTE] Các bug trên đã được kiểm chứng thực tế thông qua quá trình thực hiện test run chính thức bởi Đặng Đăng Khoa (MSSV: 23127207).

6. AI Gap Analysis Summary

- What AI missed: AI ban đầu nếu chỉ đọc spec có thể không lường trước được việc frontend admin tự fetch toàn bộ orders rồi tự tính toán doanh thu trên giao diện thay vì gọi qua một API thống kê chuyên biệt.
- What human corrected: Sinh viên kiểm thử thực tế trên hệ thống và phát hiện lỗi hiển thị nhân đôi doanh thu cũng như lỗi hồng bỏ sót kiểm tra vai trò admin khi truy cập API.
- Why the gap happened: AI không có quyền truy cập động trực tiếp và trải nghiệm UI/API của môi trường runtime nếu không thực hiện kiểm thử khám phá và thực nghiệm trực tiếp.
- Lesson learned: Luôn luôn kết hợp kiểm thử khám phá và thực nghiệm trực tiếp trên hệ thống song song với đặc tả yêu cầu khi thiết kế kịch bản test.

7. Evidence

- Screenshot folder: [tests/bug/dashboard/evidences/](#)
 - Video/demo link nếu có: N/A
 - GitHub Issue links: [Issues #156 - #160](#)
-

FR-21 – Mobile Cart & Checkout

1. Feature Overview

- Pool: Pool D (Mobile App)
- Actor: Customer / Guest / Backend API
- Related UI: `/cart` (Mobile), `/checkout` (Mobile), `/profile` (Mobile)
- Related API: `POST /api/checkout`, `PUT /api/users/me`, `GET /api/orders/my-orders`
- Preconditions:
 - Ứng dụng di động đã được cài đặt và mở thành công.
 - Người dùng có thể thêm sản phẩm vào giỏ hàng.
 - Phải đăng nhập (có token) và cập nhật thông tin giao hàng trong Profile để checkout.
- Business Rules:
 - Người dùng chưa đăng nhập không được checkout.
 - Không đặt hàng với giỏ hàng rỗng.
 - Thêm sản phẩm trùng ID phải cộng dồn số lượng.
 - Khi cập nhật/xóa sản phẩm, tổng tiền phải được tính lại.
 - Thông tin giao hàng bắt buộc: Họ tên, Số điện thoại, Địa chỉ.
 - Sau khi đặt hàng thành công, làm rỗng giỏ hàng.
 - Chống nhấp đặt hàng nhiều lần liên tục (double click).

2. Domain Testing Summary

- Link/detail: <reports/FR-21/domain-testing.md>
- Number of Domain Test Cases: 19
- Main valid partitions: Đăng nhập hợp lệ, Thêm sản phẩm còn tồn kho, Cộng dồn sản phẩm trùng, Xóa sản phẩm khỏi giỏ, Đặt hàng 1 lần.
- Main invalid partitions: Khách vắng lai checkout, Giỏ hàng rỗng, Token hết hạn, Cập nhật số lượng âm/chữ/ký tự đặc biệt, Họ tên/SĐT/Địa chỉ trống, Nhấp đặt hàng nhiều lần liên tiếp, Giả mạo giá tiền (Price Tampering).
- Human review notes: BVA và kiểm thử khám phá giúp phát hiện ra lỗi hỏng API backend thiếu kiểm tra đơn giá sản phẩm và 4 lỗi logic nghiêm trọng ở giao diện di động.

3. Boundary Value Analysis Summary

- Link/detail: <reports/FR-21/boundary-value-analysis.md>
- Boundary variables: Số lượng sản phẩm (Quantity), Độ dài số điện thoại, Độ dài họ tên, Độ dài địa chỉ giao hàng, Số dòng sản phẩm trong giỏ.
- Number of BVA Test Cases: 22
- Important boundary values:
 - Quantity: 0 (invalid), 1 (min), 2 (min+1), 4 (maxStock-1), 5 (maxStock), 6 (maxStock+1).
 - Độ dài Số điện thoại: 0, 8 (invalid), 9 (min), 10 (max), 11 (invalid).
 - Độ dài Họ tên: 0, 1 (min), 2 (min+1), 50 (max), 51 (invalid).
 - Độ dài Địa chỉ: 0, 4 (invalid), 5 (min), 6 (min+1), 255 (max), 256 (invalid).
 - Số dòng sản phẩm: 0 (invalid), 1 (min), 2 (min+1).
- Human review notes: BVA giúp phát hiện logic hệ thống chặn đầu số 0 của số điện thoại Việt Nam và lỗi ứng dụng di động tự động cắt bớt sản phẩm cuối khi thanh toán nhiều sản phẩm.

4. Test Execution Summary

Total TC	Executed	Passed	Failed	Blocked	Not Executed
43	4	2	2	0	39

5. Bugs Found (Phát hiện qua kiểm thử chức năng và tích hợp)

Bug ID	Title	Related Test Case	Severity	Priority	GitHub Issue	Evidence
BUG-FR21-D-01	Giao dịch Checkout thiếu thuộc tính địa chỉ giao hàng gửi lên API	TC-MOBILE-CART-DT-019	Major	High	Issue #161	[Giao diện ứng dụng di động]
BUG-FR21-D-02	Nhập số lượng trực tiếp trong giỏ hàng bị cộng thêm 1 đơn vị	TC-MOBILE-CART-DT-007	Major	High	Issue #162	[Giao diện ứng dụng di động]
BUG-FR21-D-03	Hồ sơ mobile không chấp nhận số điện thoại bắt đầu bằng số 0	TC-MOBILE-CART-DT-015, TC-MOBILE-CART-BVA-009	Medium	High	Issue #163	[Giao diện ứng dụng di động]
BUG-FR21-D-04	API <code>/api/checkout</code> thiếu kiểm định tính toàn vẹn của đơn giá (Price Tampering)	TC-MOBILE-CART-DT-018	Critical	High	Issue #164	[API Kiểm thử bảo mật]
BUG-FR21-D-05	Hệ thống không áp dụng được mã giảm giá khi tổng giá trị đơn hàng bằng đúng giá trị tối thiểu quy định	TC-MOBILE-CART-BVA-023	Major	High	Issue #165	[API Kiểm thử chức năng]
BUG-FR21-D-06	API áp dụng mã giảm giá tính sai số tiền giảm giá phần trăm (percent)	TC-MOBILE-CART-DT-020	Critical	High	Issue #166	[API Kiểm thử chức năng]

6. AI Gap Analysis Summary

- What AI missed: Bỏ sót địa chỉ giao hàng khi đặt hàng, chặn số điện thoại bắt đầu bằng số 0, API thanh toán chấp nhận số tiền tùy ý, lỗi áp dụng mã giảm giá khi tổng tiền bằng giá trị tối thiểu, và lỗi tính toán sai số tiền giảm giá phần trăm.
- What human corrected: Thực hiện kiểm thử khám phá trên giao diện và API để phát hiện và lập danh mục 6 lỗi logic và bảo mật nghiêm trọng.
- Why the gap happened: AI nếu chỉ đọc tài liệu yêu cầu (spec) sẽ giả định hệ thống hoạt động hoàn hảo và bỏ sót các lỗi logic phát sinh trong quá trình cài đặt thực tế.
- Lesson learned: Thiết kế test case cần kết hợp kiểm thử khám phá thực tế để bao phủ các kịch bản thực thi lỗi logic và bảo mật API.

Đánh Giá Tự Phê Bình AI

Trong quá trình sử dụng AI để hỗ trợ kiểm thử các chức năng FR-02, FR-07, FR-13 và FR-21, tôi nhận thấy AI rất hữu ích trong việc tạo nhanh cấu trúc test case, chia phân vùng tương đương, đề xuất giá trị biên và chuẩn hóa báo cáo Markdown. Tuy nhiên, AI vẫn có nhiều điểm thiếu sót khi chỉ dựa vào đặc tả hoặc prompt ban đầu. Với FR-02, AI ban đầu chưa phát hiện đầy đủ các lỗi liên quan đến race condition, độ nhạy chữ hoa/thường của email và trạng thái khóa tài khoản sau khi reset mật khẩu. Với FR-07 và FR-21, AI thường giả định backend sẽ tự kiểm tra dữ liệu hợp lệ, nên bỏ sót các lỗi nghiêm trọng như giả mạo đơn giá, thiếu kiểm tra productId, sai logic số lượng và lỗi tính mã giảm giá. Với FR-13, nếu không kiểm thử trực tiếp, AI khó phát hiện lỗi doanh thu bị nhân đôi hoặc API admin thiếu kiểm tra role.

Nguyên nhân chính là AI không trực tiếp trải nghiệm UI, không quan sát database/runtime và không tự xác minh phản hồi API nếu người dùng không yêu cầu cụ thể. Bài học tôi rút ra là AI chỉ nên được dùng như một trợ lý có kỷ luật, không phải nguồn kết quả cuối cùng. Người kiểm thử vẫn phải phản biện output, chạy test thực tế, kiểm tra evidence và bổ sung exploratory testing để phát hiện các lỗi logic/bảo mật mà AI dễ bỏ qua.